CSS4003 · Final Project — Grading rubric (40 points)

Part	Points
A. Report (graded by the areas below)	20
B. Presentation & demo	8
C. Oral defence	12

A. Report — 20 points

Each area is graded **full / partial / none** from the evidence in the report (screenshots, command output, links to files, commits and pipeline runs). No evidence = no points, even if it exists in the repo.

#	Area	Max	Full	Partial (≈ half)
1	Linux operations	1	backup/restore/healthcheck scripts with `set -euo pipefail`, scheduled per variant, automated VM bootstrap	scripts exist but not scheduled, or no error handling
2	Git workflow	1.5	protected `main`, ≥ 8 merged PRs over time, conventional commits, ≥ 3 semver Releases + CHANGELOG, gitleaks clean	branch protection or Releases missing; history done in one day
3	Cloud & network	1.5	own VPC with variant CIDR, public/private split, least-privilege rules, DB unreachable from internet (proven), no keys on VMs	network works but DB/SSH too open, or not proven
4	Docker & registry	1.5	multi-stage non-root small image, SHA + semver tags in ECR/AR, compose works	image in registry but `latest`-only or runs as root
5	Orchestration	2.5	cluster per `cluster` variant on cloud VMs; node failure drill shown (2-node / managed); Deployment ≥ 2 replicas with limits and probes, Service + Ingress, HPA at `hpa_cpu_target` shown scaling, ConfigMaps/Secrets, DB StatefulSet+PVC (or VM), zero-error rolling update, rollback shown	app runs in k8s but missing HPA, probes, rollback or the node drill
6	Database, roles, backups	2	variant engine self-hosted, admin/app_rw/app_ro proven least privilege, password policy in DB **and** endpoint, scheduled backups to object storage with retention, **restore demonstrated**; ClickHouse if variant requires	roles or backups present but restore not tested, or policy only in one place
7	Secret management	1.5	all secrets in cloud secret manager, delivered to pods (ESO or sync), rotation shown	secrets in manager but copied by hand into the cluster; no rotation
8	Security checks	1.5	gitleaks, Trivy (fails on HIGH/CRITICAL), pip-audit, IaC scan, password-policy job — all blocking; one blocked PR shown	some gates present or not blocking

#	Area	Max	Full	Partial (≈ half)
9	Monitoring	1.5	Prometheus scraping app + node + DB, Grafana RED dashboard in repo, ≥ 3 alerts incl. `alert_error_rate_pct` and `alert_p95_ms`, one fired on purpose	dashboard but no alerts, or alerts never tested
10	Logging	1	central logs per `logging_stack`, one `request_id` traced, retention set	logs collected but no trace query / retention
11	CI/CD	2	PR CI, CD on `main` with SHA tags, tag release behind Environment approval, documented rollback, no long-lived keys	CI only, or manual deploys
12	Infrastructure as code	1.5	Terraform for network/VMs/cluster/registry/buckets/firewall/secret placeholders, clean plan, destroy+apply proof, no state in git	partial Terraform, parts clicked in console
13	Documentation & portfolio	1	README with diagram, deploy/rollback docs, ≥ 4 ADRs, cost estimate + teardown proof, 3–5 min video	README without diagram/ADRs or no video
	Total	**20**		

B. Presentation & demo — 8 points

Criterion	Points
Clear story: problem → architecture → how it's deployed → how it's operated	2
Live demo (or video if destroyed): app via URL, a deploy through the pipeline, a dashboard, a log query	4
Within time (~7 min), slides/diagram readable	2

C. Oral defence — 12 points

3–5 questions about **your** project (from the instructor's question bank), possibly one live task (roll back, scale, find a request in logs, show a role's privileges). Each answer: full / partial / none.

Level	Points
Explains own decisions and code confidently, handles the live task	10–12
Mostly correct, small gaps	7–9
Did the work but explains little	4–6
Can't explain own work	0–3

Penalties and caps

Situation	Effect
A real secret (password, key, token) found in the repo history, an image or CI logs	–3, and the Secrets area = 0
Database reachable from the internet	–2, and the Network area = 0
Managed cloud DB used instead of self-hosted	DB area = 0
Variant parameters missing or not yours	Report = 0
Can't explain an area at the defence	that area's report points are removed
Identical/plagiarised repos, histories or reports	all involved capped at the defence points (C) only
Orchestration shown only on local `kind` / `k3d` (credits ran out)	Orchestration area capped at half